

The Importance of PCI Compliance

A case study on what compliance actually costs — and why non-compliance costs more



\$1K–\$5K

Annual compliance cost
for a small business



\$120K–\$1.24M

Average breach cost
for a small business



\$5K–\$100K

Monthly non-compliance
fines from card brands



0

Fully PCI-compliant orgs
found breached (Verizon)

The bottom line: PCI compliance is not optional for any business that accepts credit cards. The cost of compliance is a fraction of the cost of a single breach. Verizon's forensic investigators have never found a fully PCI-compliant organization at the time of a confirmed breach — not once.

Who Needs PCI Compliance?

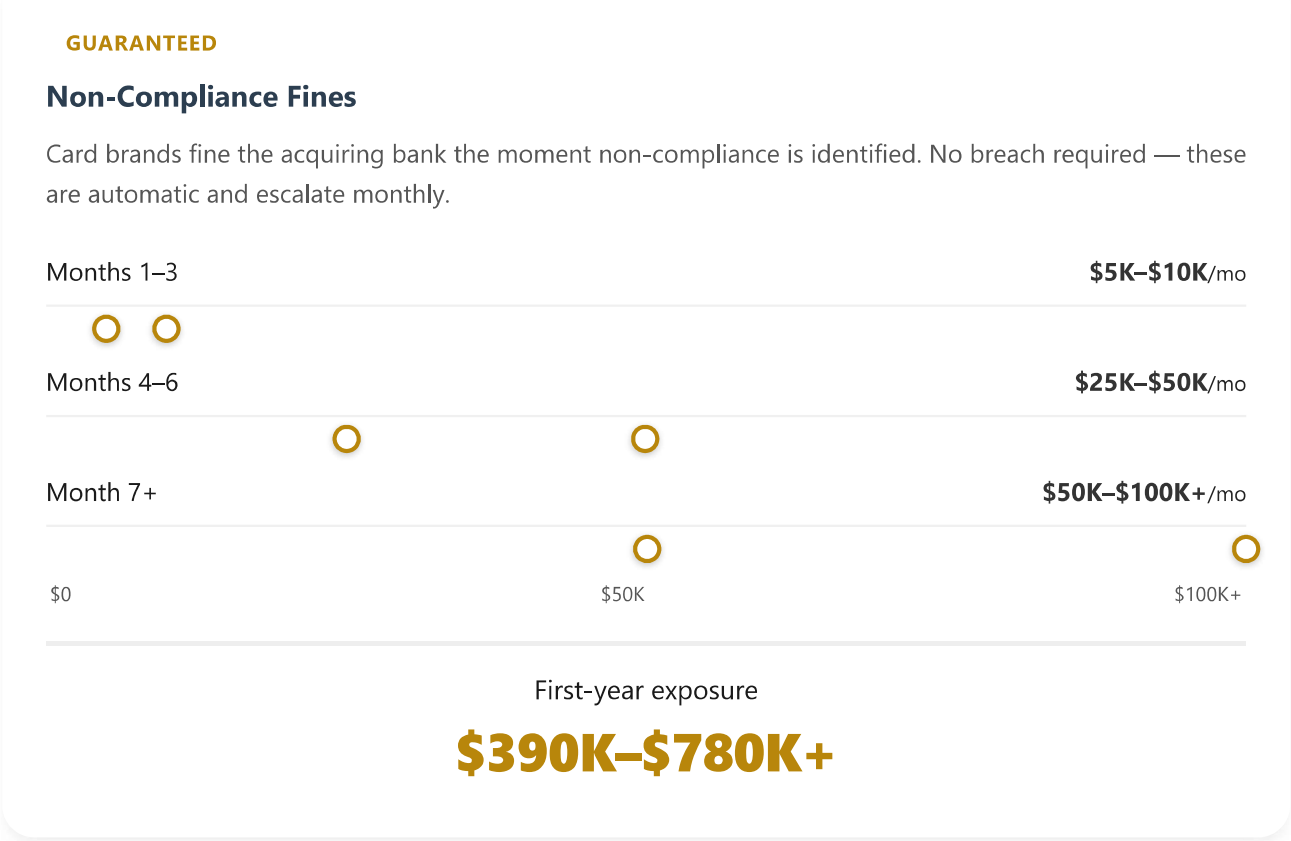
Any business that stores, processes, or transmits cardholder data must comply with PCI DSS (Payment Card Industry Data Security Standard). This includes:

- Brick-and-mortar stores with card readers or POS terminals
- Online stores accepting credit card payments
- Restaurants, hotels, and hospitality businesses
- Service businesses that invoice by card
- Any business using a payment gateway, even if the processor handles the transaction

Size does not matter. A single-location coffee shop and a multinational retailer are both subject to PCI DSS — the difference is the level of assessment required.

The Cost of Non-Compliance

Non-compliance costs in two ways: fines that begin immediately — whether or not a breach occurs — and breach costs that can compound into six or seven figures.



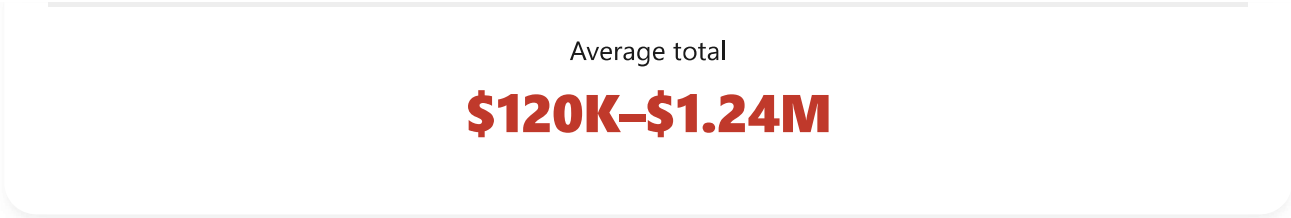
IF BREACHED

Breach Response Costs

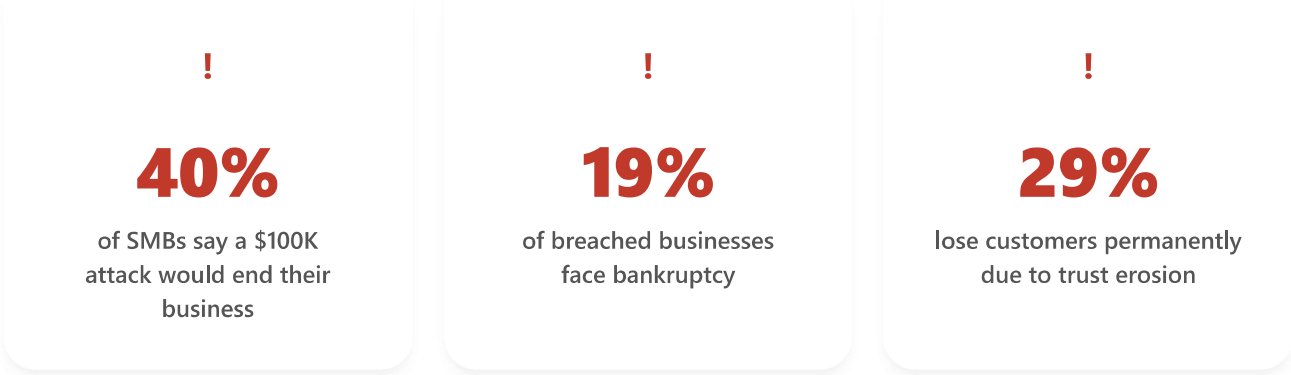
When a breach occurs, costs compound quickly. 61% of SMBs experienced a breach in the past year.

PCI forensic investigation	\$8K–\$100K+
Card replacement	\$3–\$25/card
Incident response	\$300–\$1K/hr
Customer notification	Varies by state
Fraud liability	6–7 figures
Legal fees & audits	Varies

MATCH list: After a breach or repeated violations, a business can lose the ability to process credit cards for up to **5 years**. For retail and hospitality, this is a death sentence.



Business survival after a breach



Sources: VikingCloud 2025, Verizon 2025 DBIR, industry surveys.

Small Businesses Are the Primary Target

STATISTIC	VALUE	SOURCE
Cyberattacks targeting businesses under 1,000 employees	43–46%	Verizon 2025 DBIR
SMBs that experienced a breach in the past year	61%	Industry surveys
Ransomware involvement in SMB breaches	88%	Verizon 2025 DBIR
Ransomware in large enterprise breaches	39%	Verizon 2025 DBIR
Average time to detect a breach	181 days	IBM 2025
Average time to contain after detection	60 days	IBM 2025

Key insight: Small businesses face a higher rate of ransomware attacks (88%) than large enterprises (39%), yet have fewer resources to recover. The average breach goes undetected for 6 months — by the time it's found, the damage is done.

Compliance Costs by Business Size

PCI DSS defines four merchant levels based on annual card transaction volume. The level determines the type and rigor of assessment required:

	LEVEL 4	LEVEL 3	LEVEL 2	LEVEL 1
Transaction volume	<20K e-com or <1M total	20K–1M e-com	1M–6M	6M+
Typical business	Most small businesses	Mid-size e-commerce	Large retailers	Major enterprises
Assessment type	Self-Assessment Questionnaire (SAQ)	SAQ + quarterly ASV scan	SAQ + ASV; some acquirers mandate QSA	Full audit by QSA (mandatory)
QSA audit required?	No	No	Sometimes	Yes
Quarterly ASV scan?	Depends on SAQ type	Yes	Yes	Yes
Annual compliance cost	\$1,000 – \$5,000	\$5,000 – \$20,000	\$10,000 – \$50,000	\$50,000 – \$500,000+

ASV = Approved Scanning Vendor (quarterly external vulnerability scan). QSA = Qualified Security Assessor (on-site audit).
SAQ = Self-Assessment Questionnaire.

What does this mean for you? At Level 4, small businesses (fewer than 20K e-commerce or 1 million total transactions) can get away with just a short Self-Assessment Questionnaire (SAQ) on a quarterly basis to reaffirm compliance — *if* they take proper security precautions like segmenting the network.

Mitigation: Shifting Responsibility and Reducing Cost

PCI compliance is not all-or-nothing. The framework itself is designed so that the less card data you touch, the less you are responsible for. Two decisions — who handles your payments and how your network is structured — determine the vast majority of your compliance burden.

Shift card data off your systems entirely

Every card transaction involves a chain of responsibility. When your business stores, processes, or transmits card data directly, you own the liability for protecting it — and you inherit the full weight of PCI compliance requirements. But if you outsource payment handling to a PCI-certified processor using a hosted payment page (Stripe Checkout, Square, PayPal), that liability shifts to them. The customer enters their card number on the processor's page, not yours. Your systems never see the card data at all.

This single decision determines which Self-Assessment Questionnaire (SAQ) you file. An SAQ is a standardized form from the PCI Security Standards Council — a set of yes/no questions about your security controls that you submit to your acquiring bank. There is no on-site auditor for Level 4 merchants; the SAQ is the audit. And the type you file depends entirely on how much card data your systems touch:

SAQ	WHO IT'S FOR	REQUIREMENTS	PEN TEST?
A	Fully outsourced (Stripe Checkout, Square, hosted payment page)	22	No
A-EP	E-commerce with partial outsourcing (your site redirects to processor)	191	Yes
B	Imprint machines or standalone dial-out terminals (no network connection)	41	No
B-IP	Standalone IP-connected terminals (no card data storage)	82	Scan only
C	Payment app connected to internet (IP terminal, mobile card reader)	160	Scan only
C-VT	Virtual terminal, manual card entry via web on an isolated machine	79	No
P2PE	PCI-validated point-to-point encryption terminals only	33	No
D	Everyone else — full assessment covering all 12 PCI DSS requirements	329	Yes

One decision, 15x difference. A hosted payment page qualifies you for SAQ A — 22 requirements, no penetration test. Handling card data yourself means SAQ D — 329 requirements and a mandatory pen test. This is not a technical decision. It is a business decision that directly determines your compliance cost, audit complexity, and breach liability.

Segment the network to segment the oversight

Network segmentation is a way to reduce the amount of hoops that PCI will require you to jump through. It's cheap, easy, and saves so much work — which also saves money.

Think of PCI compliance as a forcefield. Everything inside the forcefield has to meet the full set of PCI security controls — assessed, documented, maintained. PCI calls this the **cardholder data environment (CDE)**. The forcefield must cover the entire payment pipeline: the card reader, the network switch it plugs into, the firewall managing that traffic, all the way until the data hits the internet and becomes the payment processor's problem.

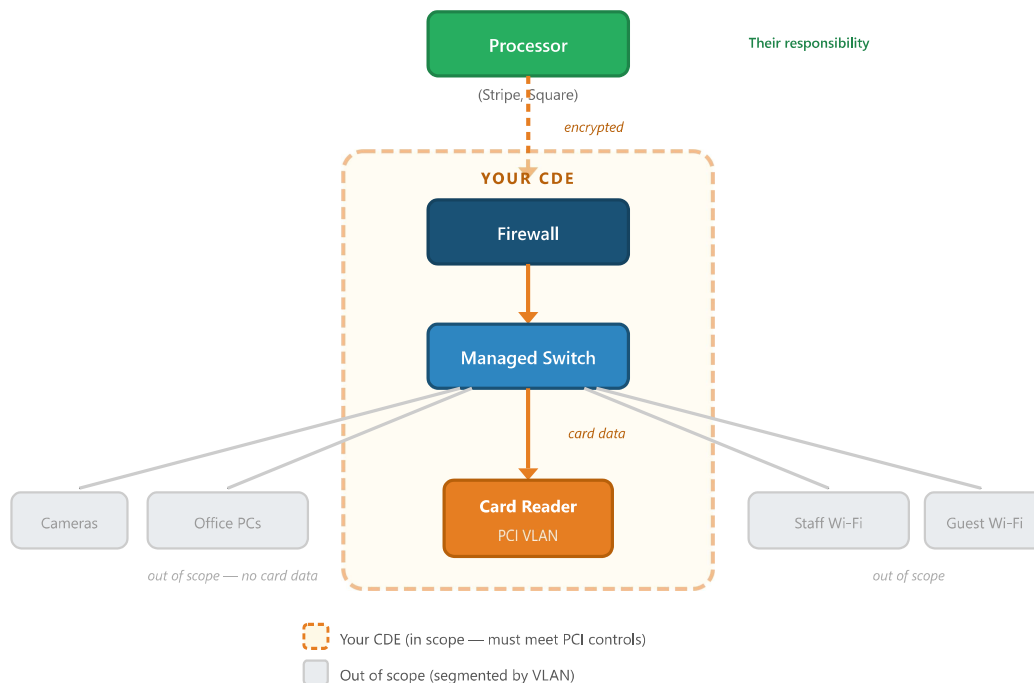
The less you put inside the forcefield, the less you have to protect. Your office workstations, security cameras, printers, guest Wi-Fi — none of those touch payment processing. So why would you put them inside the forcefield? On a flat network with no segmentation, that's exactly what happens. Everything can talk to your physical POS device, which means everything can attack your POS device, too. So now you have to make sure *everything* is compliant. Your cell phone, your printer, your laptop — it can all be under scrutiny for security measures, which costs money you don't want to spend, to overshoot the amount of security needed, and generate more hoops to jump through along the way.

If you're thinking, "Wow, that sounds terrible," you'd be right.

Q: “How do I avoid this extra work?”

A: Network segmentation. It places the forcefield tightly around the payment pipeline and moves everything else outside of it. It can be done as an equipment installation relatively easily and cheaply, then managed digitally — preferably from your phone. It serves as the frontline defense for any business that handles card transactions. The frontline against having to do more work.

The [PCI-Compliant Network Roadmap](#) is a more technical document, but even business owners can benefit from seeing the inner workings of how their operation runs. There are plenty of ways to upgrade a system, and the guide can be used as a quick reference to understand the expectations and costs associated with such a murky and confusing concept — with hard facts and a reality check.



Fewer systems in scope means fewer controls to maintain, fewer things to assess, and a smaller blast radius if something goes wrong.

Stacks on stacks, in more ways than one. Stack the benefits from outsourcing payment handling (shift liability off your books) + benefits from segmenting your network (shrink what’s included in audits) = two stacks of cash saved in your wallet. A small business that does both can go from 329 auditable requirements to 22 — and move the costliest breach liability to a processor whose entire business is protecting card data. “Let them deal with it,” is what I say. Strategically dump the burden on another vendor. **Do it.** You know you want to.

PCI DSS 4.0: What You Need to Do Now

As of right-now-o'clock, there are new PCI DSS requirements that you might be failing to meet. Go ahead and review the changes made in March 2025 below. There's a new sheriff in town. And he's kind of a pushover if you get to know him.

WHAT CHANGED	WHAT TO DO	COST
MFA required for all CDE access (not just admins)	Enable MFA on every account that touches the cardholder data environment. Microsoft Authenticator, Google Authenticator, or Duo all work. If your POS vendor supports MFA, turn it on. SEGMENTATION <i>If your CDE is just a card reader on an isolated VLAN, the only accounts that need MFA are the ones that manage the firewall and POS — not every employee in the building. See the Roadmap →</i>	Free
12-character minimum passwords (up from 8)	Update your password policy in Active Directory, your router, and your POS admin panel. Any existing passwords under 12 characters need to be rotated immediately — they are already non-compliant. Deploy a password manager to make 12+ character passwords practical for staff. See the Hardening Guide for options. OUTSOURCING <i>Let the password manager deal with it. It generates and fills 12+ character passwords — staff never memorize anything.</i>	\$4/user/mo
Payment page script monitoring	If you use a hosted payment page (Stripe, Square), this is the processor's responsibility — not yours. If you run your own checkout page, you need a tool like Subresource Integrity (SRI) or a CSP policy to detect unauthorized script changes. OUTSOURCING <i>With a hosted payment page, this entire requirement is someone else's problem.</i>	Free – \$50/mo
Authenticated vulnerability scanning	Your quarterly ASV scan now needs to authenticate into systems, not just scan from outside. Ask your ASV provider if their scan supports authenticated mode. If you handle this in-house, configure credentialed scans in your scanner. SEGMENTATION <i>Fewer systems in the CDE means fewer systems to scan. A single card reader on its own VLAN is a much smaller target than an entire flat network. See the Roadmap →</i>	Included in ASV
Firewall and segmentation review every 6 months (was annual)	Put two dates on the calendar — January and July. Walk your firewall rules, verify VLANs are still isolated, confirm no new devices bridged into the CDE. Document it. A one-page checklist is enough — download the template. SEGMENTATION <i>The architecture is already documented in the Network Roadmap. Your semi-annual review is just confirming nothing changed.</i>	Free

WHAT CHANGED	WHAT TO DO	COST
Annual scoping documentation	Write down every system in your CDE: POS terminals, the switch they connect to, the firewall, the server (if any). Update this list once a year. If a device gets added or removed, update the list then too. SEGMENTATION <i>Your scoping document is three lines — card reader, switch, firewall. Not a spreadsheet of every device in the building. See the Roadmap →</i>	Free

The pattern here: PCI DSS 4.0 shifted from a once-a-year checkbox exercise to ongoing operations. Most of what it asks for is free — MFA, longer passwords, documented reviews. The cost is not money. It is discipline. And if you've already segmented your network and outsourced payment handling, half of these requirements either shrink to almost nothing or become someone else's job entirely.

Common Mistakes Small Businesses Make

"We're too small to be targeted."

43–46% of cyberattacks target businesses under 1,000 employees. Attackers specifically seek out small businesses because they tend to have weaker defenses.

"Our payment processor handles everything."

Even with a hosted payment page, the business is still responsible for network security, access controls, and SAQ filing. The processor does not make you compliant.

"We don't store card numbers."

PCI DSS applies to any business that *transmits* or *processes* card data, not just those that store it. If a card is swiped, dipped, or tapped at your terminal, you're in scope.

"Our network is fine as-is."

A flat network with no segmentation means every device is in PCI scope. One compromised laptop gives an attacker a path to the card reader.

"Everyone uses the same login."

PCI DSS requires unique logins. Shared credentials on POS systems make it impossible to audit who accessed what and when.

"We did this last year, we're good."

PCI DSS 4.0 explicitly requires ongoing monitoring, semi-annual reviews, and continuous security operations. Compliance is not a one-time project.

The ROI of Compliance



FACTOR	IMPACT
Non-compliance cost multiplier	2.71x more expensive than maintaining compliance
Additional breach cost from non-compliance	+\$174,538 added to average breach
Tested incident response plan	\$2.66M savings per breach
Faster detection (under 200 days)	\$1.14M savings per breach
Cyber insurance premiums	10–25% reduction with documented security controls

Sources: Ponemon Institute, IBM 2025 Cost of a Data Breach Report, industry surveys.

The math: A Level 4 small business spends roughly \$1,000–\$5,000 per year on compliance and \$315–\$670 one-time on network hardware. A single breach costs 25x to 250x that amount — and 40% of small businesses say a \$100K attack would end their business entirely. Compliance is not an expense. It is the cheapest insurance a small business can buy.

Getting Started

For a small business, PCI compliance starts with three things:

1. **Segment your network.** Isolate the card reader on its own VLAN so a compromised laptop or camera cannot reach it. This is the single most impactful step.
2. **Choose the right payment integration.** A hosted payment page (Stripe, Square) drops your self-assessment questionnaire from 329 requirements to 22.
3. **File your SAQ.** The SAQ is how you demonstrate compliance. Your payment processor or acquiring bank can tell you which one applies.

Ready to build the network? See the [PCI-Compliant Network Roadmap](#) for a complete topology template with VLAN segmentation, firewall rules, and an equipment cost breakdown starting at \$315.

PCI COMPLIANCE SERIES

► **Part 1: The Importance of PCI Compliance** (you are here)

Part 2: **PCI-Compliant Network Roadmap** — Equipment, VLANs, firewall rules

Part 3: **PCI Hardening Basics** — Endpoint protection, passwords, POS security

Part 4: **Employee Security Training** — Phishing, social engineering, incident reporting